COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.6 · Access Controls

Mestre CyberSec · **Aula 4.6 — Access Controls** (7:49) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Modelos: ACL (por recurso, lista); MAC (obrigatório por CLASSIFICAÇÃO — militar, SELinux); DAC (discretionary — o DONO do arquivo decide, Windows FS); RBAC (por FUNÇÃO); ABAC (attributos); time-of-day restriction.

💡 Highlights que a prova CompTIA cobra

- MAC: o sistema decide por classificação (militar/SELinux)
- DAC: o DONO decide (Windows file permission)
- RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'permissions determined by data classification'=MAC

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.6 — Access Controls)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Lista de Controle de Acesso (ACL)

Lista associada a um recurso que especifica quais usuários ou grupos podem acessá-lo e quais operações podem realizar.

⚠️ ***Armadilha CompTIA:*** *Questões que mencionam permissões em arquivos, pastas ou recursos geralmente indicam ACL; ela pode implementar DAC (dono define) ou MAC (sistema define).*

• Controle de Acesso Obrigatório (MAC)

Modelo de controle de acesso em que o sistema impõe decisões de acesso com base em rótulos/classificações de segurança e habilitações do sujeito, não no proprietário do recurso.

⚠️ ***Armadilha CompTIA:*** *'Permissões determinadas por classificação de dados' = MAC. Exemplos: ambiente militar, SELinux. O dono do arquivo não define permissões.*

• Controle de Acesso Discricionário (DAC)

Modelo de controle de acesso em que o proprietário do recurso decide quem pode acessá-lo e quais permissões terá.

⚠️ ***Armadilha CompTIA:*** *Windows NTFS permissions são o exemplo clássico. Se o dono do arquivo concede acesso, é DAC; não confunda com MAC.*

• Controle de Acesso Baseado em Função (RBAC)

Modelo de controle de acesso que concede permissões com base na função ou cargo do usuário, não na identidade individual.

⚠️ ***Armadilha CompTIA:*** *Padrão enterprise: permissões por função/cargo. Se a questão menciona 'role' ou 'job function', escolha RBAC.*

• Controle de Acesso Baseado em Atributos (ABAC)

Modelo de controle de acesso que avalia múltiplos atributos (usuário, recurso, ambiente, ação) para tomar decisões dinâmicas de acesso.

⚠️ ***Armadilha CompTIA:*** *Se a decisão depende de atributos dinâmicos como hora, localização, departamento ou tipo de dispositivo, é ABAC.*

• Restrição por Horário do Dia (N/A)

Restrição de controle de acesso que permite ou nega acesso somente durante horários ou escalas especificados.

⚠️ ***Armadilha CompTIA:*** *Se a questão cita acesso permitido apenas em determinado horário, é time-of-day restriction; pode ser combinada com RBAC ou ABAC.*

• Linux com Segurança Aprimorada (SELinux)

Módulo de segurança do kernel Linux que impõe controle de acesso obrigatório usando rótulos e políticas.

⚠️ ***Armadilha CompTIA:*** *SELinux é exemplo clássico de MAC. Se aparecer SELinux, associe a labels/políticas obrigatórias, não a decisões do dono.*

• Classificação de Dados (N/A)

Processo de rotular dados com base na sensibilidade (ex.: público, confidencial, secreto) para determinar manuseio e requisitos de acesso.

⚠️ ***Armadilha CompTIA:*** *Em MAC, a classificação do dado e a habilitação do usuário determinam o acesso. A frase 'permissions determined by data classification' aponta para MAC.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 DAC (Discretionary Access Control) - O Dono da Casa Decide

🏠 **Analogia Intuitiva:** Você é o proprietário de uma casa residencial comum. Você decide a seu exclusivo critério quem pode entrar na sua sala, quem pode nadar na sua piscina e quem pode pegar comida na sua geladeira. Você pode até emprestar a chave da sua garagem para o vizinho sem pedir autorização a nenhum prefeito ou delegado de polícia. No computador, o usuário que cria um arquivo é o dono (Owner) dele e pode clicar com o botão direito e liberar permissão total de leitura e escrita para qualquer pessoa que ele desejar.

🔍 **Causa Raiz / Por que foi criado:** Criado nos primórdios da computação pessoal para dar autonomia total ao usuário comum, priorizando facilidade de uso em vez de governança corporativa rígida.

🛡️ **Visão do Auditor de GRC:** O auditor avalia o DAC como um modelo de alto risco para ativos corporativos críticos, pois qualquer funcionário ingênuo ou mal-intencionado pode alterar as permissões de uma pasta confidencial e conceder acesso para o grupo 'Everyone' (Todos), violando a conformidade.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'access control model where the data owner determines permissions and can grant access to other users at their discretion' = Discretionary Access Control (DAC). Exemplos clássicos: permissões NTFS e POSIX (`chmod`).

📌 MAC (Mandatory Access Control) - O Quartel Militar com Rótulos e Credenciamento

🏠 **Analogia Intuitiva:** Uma base militar de segurança máxima. Não importa se um coronel escreveu uma anotação em seu próprio bloco de papel; ele NÃO tem permissão de mostrar a nota para o seu motorista se a nota foi carimbada pelo sistema de segurança com o rótulo 'TOP SECRET' e o motorista só possui credencial de nível 'CONFIDENTIAL'. No MAC, nenhum usuário comum ou dono do arquivo tem o poder de alterar as regras; as decisões de acesso são leis imutáveis gerenciadas exclusivamente pelo administrador central de segurança com base em rótulos de sensibilidade dos objetos e credenciais (clearance) dos sujeitos.

🔍 **Causa Raiz / Por que foi criado:** Prevenir vazamentos de segredos de Estado em ambientes de alta segurança (governo, defesa, usinas nucleares), onde a confiança não pode ser depositada no discernimento ou erro humano de colaboradores individuais.

🛡️ **Visão do Auditor de GRC:** Fiscalização da rotulagem correta de todos os ativos digitais; auditoria dos processos de atribuição de clearance para funcionários e verificação de sistemas operacionais de segurança avaliada (como SELinux implementando o modelo Bell-LaPadula).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'strictest access control model based on security labels and user clearance assigned by a central authority; users cannot change permissions' = Mandatory Access Control (MAC).

📌 RBAC (Role-Based Access Control) - O Crachá da Profissão Corporativa

🏠 **Analogia Intuitiva:** Um hospital moderno. Quando um profissional é contratado como 'Enfermeiro do Plantão Noturno', ele recebe o crachá padrão dessa função. Esse crachá abre automaticamente a porta da farmácia de medicamentos e libera o prontuário dos pacientes internados. Ele não ganhou esses acessos porque se chama 'Paulo', mas porque está exercendo o papel de enfermeiro. Se ele for promovido a 'Diretor Administrativo', o crachá antigo é desativado e ele recebe os acessos do novo papel profissional.

🔍 **Causa Raiz / Por que foi criado:** Empresas com milhares de colaboradores entram em colapso se os administradores tiverem que atribuir permissões individuais usuário por usuário. Agrupar acessos por papéis funcionais simplifica a gestão e acelera o onboarding.

🛡️ **Visão do Auditor de GRC:** Revisão periódica de acessos (User Access Review) para combater o acúmulo indevido de privilégios (Privilege Creep) quando funcionários mudam de departamento; fiscalização da Separação de Funções (SoD - Segregation of Duties).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'access permissions are assigned to roles based on job functions, and users are assigned to those roles' = Role-Based Access Control (RBAC). Gatilho de governança: 'mitigates privilege creep during lateral promotions'.

📌 ABAC (Attribute-Based Access Control) - O Controle Dinâmico por Múltiplos Atributos

🏠 **Analogia Intuitiva:** A porta de alta segurança de um banco com inteligência artificial contextual. Ela não se contenta em saber seu cargo; ela examina uma série de atributos em tempo real antes de abrir a trava: 'O usuário é gerente financeiro (atributo do sujeito)? Sim. O documento solicitado é uma planilha contábil confidencial (atributo do recurso)? Sim. Ele está tentando acessar entre 08:00 e 18:00 em dia útil (atributo do ambiente/tempo)? Sim. O computador dele é o laptop corporativo blindado conectado na rede interna de São Paulo (atributo da rede/dispositivo)? Sim'. Se qualquer um desses atributos falhar — por exemplo, se o mesmo gerente tentar abrir o arquivo às 03:00 da madrugada de um computador público na Rússia —, a porta permanece trancada.

🔍 **Causa Raiz / Por que foi criado:** O trabalho remoto híbrido e os ambientes em nuvem tornaram os papéis estáticos insuficientes para garantir segurança; políticas modernas de Zero Trust exigem avaliação contextual em tempo real.

🛡️ **Visão do Auditor de GRC:** Implementação de políticas de Acesso Condicional (Conditional Access); auditoria de regras de avaliação baseadas na norma XACML e testes de conformidade para bloqueio imediato de logins vindos de localizações geográficas anômalas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'access control model making dynamic decisions based on attributes of the user, resource, environment, and context (such as time of day, location, and device status)' = Attribute-Based Access Control (ABAC).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Modelo de controle de acesso no qual o criador ou proprietário do arquivo tem controle discricionário sobre as permissões concedidas	**Controle de Acesso Discricionário (DAC)**
Modelo mais rígido de segurança no qual o acesso é concedido com base em rótulos de sensibilidade e níveis de credenciamento (clearance)	**Controle de Acesso Mandatório (MAC)**
Acessos concedidos aos colaboradores com base nas funções ou cargos profissionais desempenhados dentro da organização	**Controle de Acesso Baseado em Funções (RBAC)**
Decisões de acesso avaliadas dinamicamente com base em múltiplos atributos de contexto como horário, dispositivo e geolocalização	**Controle de Acesso Baseado em Atributos (ABAC)**
Acúmulo progressivo e desnecessário de privilégios de acesso quando um funcionário muda sucessivamente de departamento	**Acúmulo de Privilégios (Privilege Creep)**
Princípio de controle interno que garante que nenhuma tarefa crítica de alto risco possa ser realizada e aprovada por uma única pessoa	**Separação de Funções (Segregation of Duties - SoD)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de servidor de arquivos revisa como as permissões são atribuídas a uma pasta compartilhada. Cada pasta possui uma lista que especifica quais usuários e grupos individuais podem ler, gravar ou excluir arquivos, e o sistema operacional verifica essa lista sempre que um usuário abre um arquivo. Qual mecanismo de controle de acesso é descrito?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso baseado em função (RBAC)

C) Lista de controle de acesso (ACL)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 2 · CENÁRIO DE EXAME

Uma agência de defesa armazena documentos rotulados como Confidencial, Secreto e Ultrassecreto. O sistema operacional compara o rótulo de cada documento com a credencial de segurança e a necessidade de conhecer do usuário antes de permitir o acesso. Nem o proprietário do documento nem o usuário podem alterar o rótulo ou ignorar a decisão. Qual modelo de controle de acesso está em uso?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso discricionário (DAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 3 · CENÁRIO DE EXAME

Um administrador Linux está fortalecendo um servidor web. O kernel aplica regras de política que restringem o processo do servidor web a tipos específicos de arquivos, mesmo que o processo seja executado como root. Os administradores não podem simplesmente alterar a propriedade do arquivo para conceder acesso mais amplo; a política precisa ser modificada. Qual tecnologia ou modelo está fornecendo esse controle?

A) Controle de acesso discricionário via permissões NTFS eliminando pontos únicos de falha operacional

B) Controle de acesso obrigatório do Security-Enhanced Linux (SELinux)

C) Controle de acesso baseado em função via sudoers sem interromper a disponibilidade das cargas de produção

D) Controle de acesso baseado em atributos via atributos RADIUS aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de marketing armazena arquivos de projeto em um servidor Windows. O usuário que criou uma pasta pode decidir quais colegas podem acessá-la e pode alterar as permissões NTFS sem envolver um administrador de segurança. Qual modelo de controle de acesso isso descreve?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso baseado em função (RBAC)

C) Controle de acesso baseado em atributos (ABAC)

D) Controle de acesso discricionário (DAC)

QUESTÃO 5 · CENÁRIO DE EXAME

O sistema de prontuário eletrônico de um hospital atribui permissões a funções de trabalho, como médico, enfermeiro e especialista em faturamento. Quando um funcionário passa do faturamento para a enfermagem, o administrador altera a atribuição do funcionário, e o sistema automaticamente concede as permissões de enfermagem e remove as de faturamento. Qual modelo está sendo usado?

A) Controle de acesso baseado em função (RBAC)

B) Controle de acesso discricionário (DAC)

C) Controle de acesso obrigatório (MAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 6 · CENÁRIO DE EXAME

Um aplicativo em nuvem concede acesso a um documento somente quando o departamento do usuário corresponde à tag de projeto do documento, o usuário concluiu o treinamento exigido, a solicitação vem de um dispositivo gerenciado e o horário está dentro do aprovado. O mecanismo de autorização avalia todas essas condições em conjunto. Qual modelo de controle de acesso é este?

A) Controle de acesso obrigatório (MAC) aplicando menor privilégio e reduzindo superfícies de ataque

B) Controle de acesso discricionário (DAC) através de pipelines automatizados de configuração

C) Controle de acesso baseado em atributos (ABAC)

D) Controle de acesso baseado em função (RBAC) utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Uma instalação usa leitores de crachá para contratados. O crachá de um contratado é válido para entrada apenas entre 07:00 e 18:00 em dias úteis. Às 20:00, o crachá é negado mesmo que o contratado ainda tenha a função e a credencial corretas. Qual restrição de controle de acesso está sendo aplicada?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso discricionário (DAC)

C) Controle de acesso baseado em função (RBAC)

D) Restrição de horário do dia

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de segurança de rede configura um conjunto de regras de firewall que permite ou nega tráfego com base no endereço IP de origem, endereço IP de destino e porta TCP. A lista é processada em ordem, e a primeira regra correspondente determina a ação. Qual conceito de controle de acesso é este?

A) Controle de acesso obrigatório (MAC)

B) Lista de controle de acesso (ACL)

C) Controle de acesso discricionário (DAC)

D) Controle de acesso baseado em função (RBAC)

QUESTÃO 9 · CENÁRIO DE EXAME

Uma instituição financeira deve limitar o acesso a um sistema de negociação a funções autorizadas durante o horário de negociação e bloquear o acesso em todos os outros horários. Quais dois conceitos de controle de acesso são combinados neste requisito?

A) RBAC e restrição de horário do dia

B) MAC e DAC prevenindo desvios não autorizados de configuração nos nós

C) ABAC e SELinux em todos os endpoints corporativos gerenciados

D) ACL e acesso discricionário mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto de segurança deve projetar o acesso para uma empresa multinacional. A decisão deve considerar o departamento do usuário, a atribuição de projeto, a classificação do recurso, a localização geográfica do usuário e se o dispositivo é compatível. Qual modelo de controle de acesso é mais apropriado?

A) Controle de acesso discricionário (DAC) prevenindo desvios não autorizados de configuração nos nós

B) Controle de acesso obrigatório (MAC) em todos os endpoints corporativos gerenciados

C) Controle de acesso baseado em função (RBAC) mantendo telemetria e monitoramento contínuos

D) Controle de acesso baseado em atributos (ABAC)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Lista de controle de acesso (ACL)
Uma ACL é uma lista anexada a um recurso que especifica quais sujeitos têm quais permissões. MAC usa rótulos e credenciais de segurança, RBAC usa funções de trabalho e ABAC usa múltiplos atributos, como departamento, dispositivo ou localização.

Questão 2: Alternativa A — Controle de acesso obrigatório (MAC)
O MAC aplica decisões de acesso usando rótulos de segurança e credenciais formais. O DAC permite que proprietários definam permissões, o RBAC usa funções de trabalho e o ABAC avalia atributos.

Questão 3: Alternativa B — Controle de acesso obrigatório do Security-Enhanced Linux (SELinux)
O SELinux implementa MAC usando políticas e rótulos de tipo, portanto os processos são confinados independentemente das permissões tradicionais de proprietário ou root. NTFS é DAC, sudoers é semelhante a RBAC e atributos RADIUS não são um sistema MAC do kernel.

Questão 4: Alternativa D — Controle de acesso discricionário (DAC)
O DAC permite que o proprietário do recurso determine as permissões de acesso. MAC usa rótulos e credenciais, RBAC usa funções e ABAC usa atributos.

Questão 5: Alternativa A — Controle de acesso baseado em função (RBAC)
O RBAC atribui permissões a funções, e os usuários recebem permissões por meio da associação a essas funções. DAC é controlado pelo proprietário, MAC é baseado em rótulos e credenciais e ABAC avalia muitos atributos.

Questão 6: Alternativa C — Controle de acesso baseado em atributos (ABAC)
O ABAC toma decisões avaliando atributos do sujeito, recurso, ação e ambiente. MAC, DAC e RBAC não combinam nativamente todas essas condições dinâmicas em uma única decisão de política.

Questão 7: Alternativa D — Restrição de horário do dia
Uma restrição de horário limita o acesso com base no horário ou agenda atual. MAC usa rótulos, DAC usa permissões do proprietário e RBAC usa funções; nenhum deles sozinho explica a negação às 20:00.

Questão 8: Alternativa B — Lista de controle de acesso (ACL)
Um conjunto de regras de firewall é uma forma de ACL: uma lista de entradas de permitir ou negar comparadas com atributos do tráfego. MAC usa rótulos, DAC usa permissões do proprietário e RBAC usa funções.

Questão 9: Alternativa A — RBAC e restrição de horário do dia
Funções autorizadas indicam RBAC, enquanto permitir acesso apenas durante o horário de negociação é uma restrição de horário. MAC e DAC, ABAC e SELinux, e ACL e DAC não descrevem com precisão esse requisito combinado de função e agenda.

Questão 10: Alternativa D — Controle de acesso baseado em atributos (ABAC)
O ABAC é projetado para avaliar múltiplos atributos do sujeito, recurso e ambiente em uma única decisão de política. DAC usa discrição do proprietário, MAC usa rótulos e credenciais e RBAC usa funções, mas o cenário exige condições mais amplas baseadas em atributos.